Revisión de una prueba automatizada

Unidad 3.3 | Nombre o integrantes: Benjamín Ibáñez y Gerardo Vera

Sistemas analizados: Cuidarte+ (resultados de exámenes médicos) y Atlas (información de clientes y contratos). Todas las cuentas, empresas, exámenes y contratos usados son ficticios.

Parte 1 · Diagnóstico

a) Resultados esperados comprobables

- **Cuidarte+:** un paciente autenticado solo ve sus propios resultados. Comprobable así: al iniciar sesión como la cuenta ficticia pac.ana@ejemplo.cl y abrir «Mis Resultados», la lista muestra únicamente el examen E-101 (propio); al solicitar por URL o endpoint el examen E-102 (ajeno, de otro paciente), la respuesta es 403/404 y no se muestran datos.
- **Atlas:** una cuenta autenticada solo ve clientes y contratos autorizados. Comprobable así: al iniciar sesión como la cuenta ficticia empresaA@ejemplo.cl y abrir el contrato C-100 (propio), se muestra su información; al solicitar el contrato C-999 (ajeno, de otra cuenta), la respuesta es 403/404 o un mensaje de acceso denegado, sin datos.

b) Problemas de la secuencia

Problema de la secuencia	Afecta	Cómo
Esperar siempre 5 segundos	Estabilidad	Falla en falso negativo si el sistema tarda más de 5 s en cargar; desperdicia tiempo si carga en 1 s; el resultado depende del entorno y no de una condición real.
Botón ubicado por su posición exacta	Mantenimiento	Cualquier cambio de layout, resolución o pantalla responsive rompe el clic o toca otro elemento; la prueba falla sin que el sistema esté roto.
Usuario y contraseña escritos en el script	Seguridad	Si el script se sube al repositorio la credencial queda expuesta; además pueden ser credenciales reales y reutilizables en otros sistemas.
Solo imprime «prueba completada»	Seguridad y calidad	No hay ninguna verificación: la prueba siempre «pasa» aunque el acceso sea incorrecto o se muestren datos ajenos; no detecta regresiones.

c) Por qué «prueba completada» no demuestra acceso correcto

Solo confirma que el script llegó al final sin detenerse. No compara lo obtenido con ningún resultado esperado: no valida que los datos mostrados pertenezcan al usuario autenticado, ni que el examen o contrato ajeno sea rechazado, ni siquiera que la pantalla mostrada sea la correcta. Un script puede imprimir «prueba completada» sobre una pantalla de error o con datos de otro paciente. Sin una aserción que contraste obtenido vs. esperado, no hay evidencia de que el acceso sea correcto.

Parte 2 · Propuesta de mejora

1) Cuidarte+ — secuencia con preparación, acción y verificación

Escenario 1 — Acceso al examen propio (autorizado):

- **Preparación:** entorno de prueba sembrado con dos pacientes ficticios, pac.ana@ejemplo.cl (examen propio E-101) y pac.beto@ejemplo.cl (examen E-102); Page Objects LoginPage y MisResultadosPage; iniciar sesión como pac.ana@ejemplo.cl.
- **Acción:** navegar a «Mis Resultados» y abrir el examen E-101.
- **Verificación:** la vista muestra el examen E-101 con los datos del paciente A (assert por ID/nombre); la respuesta es 200; no aparece información de otros pacientes.

Escenario 2 — Rechazo del acceso a un examen ajeno:

- **Preparación:** misma sesión iniciada como pac.ana@ejemplo.cl.
- **Acción:** solicitar directamente por URL o endpoint el examen E-102 (de pac.beto).
- **Verificación:** respuesta 403/404 o mensaje «No tiene permisos»; no se muestran datos del examen E-102.

2) Atlas — los mismos dos escenarios

Escenario 1 — Acceso a un contrato autorizado:

- **Preparación:** entorno de prueba con la cuenta ficticia empresaA@ejemplo.cl y su contrato propio C-100 sembrado; iniciar sesión como empresaA@ejemplo.cl.
- **Acción:** abrir «Contratos» y abrir el contrato C-100.
- **Verificación:** se muestra la información de C-100 (assert por ID o razón social); respuesta 200; no aparece información de otras cuentas.

Escenario 2 — Rechazo del acceso a un contrato ajeno:

- **Preparación:** misma sesión iniciada como empresaA@ejemplo.cl.
- **Acción:** solicitar directamente por URL o buscador el contrato C-999 (ajeno, de otra cuenta).
- **Verificación:** respuesta 403/404 o mensaje de acceso denegado; no se revelan datos de C-999.

En ambos sistemas se usan solo datos ficticios y ambos cubren acceso autorizado y rechazo de acceso ajeno.

3) Condición de espera propuesta

Usar una espera explícita y condicional: por ejemplo, esperar hasta que el elemento esté visible y clicable (WebDriverWait / visibilityOfElementLocated) o hasta que llegue la respuesta de red esperada (p. ej. 200 en la petición del examen o contrato), con un timeout máximo. Es más útil que esperar siempre 5 segundos porque:

- se adapta a la velocidad real del sistema: espera menos si la página carga rápido y más si tarda, sin pasarse del timeout;
- falla rápido y con un mensaje claro si la condición nunca se cumple, en vez de fallar más adelante sin pista del origen;
- reduce el tiempo total de ejecución y los falsos negativos, y deja la prueba independiente del entorno donde se ejecute.

4) Organización con Page Object Model (POM)

Una clase Page Object por página/pantalla en cada sistema. Las acciones viven ahí; las verificaciones no.

Sistema	Page Objects (acciones de la página)	La prueba conserva
Cuidarte+	LoginPage: abrir(), login(usuario, clave). MisResultadosPage: abrir(), abrirExamen(id), obtenerMensajeError().	Flujo del escenario y los asserts del resultado esperado: 200 y datos propios visibles; 403/404 y sin datos ajenos.
Atlas	LoginPage: abrir(), login(usuario, clave). ContratosPage: abrir(), buscarContrato(id), abrirContrato(id), obtenerMensajeError().	Flujo del escenario y los asserts del resultado esperado: 200 y datos del contrato C-100; 403/404 y sin datos del contrato C-999.

Si cambia la interfaz (un selector, un texto, un orden de pantallas), se ajusta el Page Object una sola vez y no cada prueba. La prueba nunca sabe «cómo» se hace clic; solo ordena la acción y verifica el resultado.

5) Tratamiento de las credenciales ficticias

- Usar solo credenciales ficticias de prueba, sembradas en un entorno de pruebas; nunca credenciales reales ni cuentas personales.
- Mantenerlas fuera del repositorio: variables de entorno (.env listado en .gitignore) o «secrets» del pipeline de CI; en el repositorio solo un .env.example sin valores.
- No subir al repositorio: contraseñas o tokens reales, claves JWT, archivos .env con valores, dumps de base de datos con datos reales, ni URLs internas con usuario:contraseña.
- Si una credencial llega a subirse por error, debe rotarse (cambiarse) de inmediato, no solo borrarse del historial.

Parte 3 · Evidencia y decisión

Resultado observado	Cuidarte+	Atlas
La prueba pasa	El equipo ve una ejecución en verde: el paciente A abrió su examen E-101 (200) y el examen ajeno E-102 fue rechazado (403/404), con el reporte como evidencia.	El equipo ve una ejecución en verde: empresaA abrió su contrato C-100 (200) y el contrato ajeno C-999 fue rechazado (403/404), con el reporte como evidencia.
La prueba falla	Un assert sale en rojo: o se mostraron datos ajenos, o el examen propio no cargó, o el rechazo no ocurrió. Se analiza si es un defecto real (bloquea la liberación), una prueba desactualizada o un problema de entorno/datos; se corrige y se re-ejecuta.	Un assert sale en rojo: o se reveló el contrato C-999, o C-100 no cargó, o el rechazo no ocurrió. Se analiza si es un defecto real (bloquea la liberación), una prueba desactualizada o un problema de entorno/datos; se corrige y se re-ejecuta.
La prueba no llega a ejecutarse	Error de infraestructura, timeout en la preparación, credenciales inválidas o pipeline caído. No hay evidencia: no puede darse por aprobado; se investiga la causa y se re-ejecuta.	Error de infraestructura, timeout en la preparación, credenciales inválidas o pipeline caído. No hay evidencia: no puede darse por aprobado; se investiga la causa y se re-ejecuta.

Qué conclusión puede y no puede obtenerse de una prueba aprobada

- **Sí puede concluirse:** en ese entorno, con esos datos ficticios y para esos escenarios, el control de acceso se comportó como se esperaba en el momento de la ejecución.
- **No puede concluirse:** que el sistema es seguro en producción, para todos los usuarios, roles o rutas no probadas, ni frente a atacantes reales; ni que no existan otras vulnerabilidades; ni que seguirá funcionando así para siempre.

Una prueba aprobada es evidencia limitada y puntual, no una garantía de seguridad. Y «no ejecutada» nunca equivale a «pasa»: sin ejecución no hay conclusión posible.